1. e - The Access-Control-Allow-Credentials header is required on both the preflight response and on the actual response otherwise the browser will reject the cookie or strip it from subsequent requests.
2. c - Use a `SecureRandom` or other cryptographically secure random number generator. Remember that while the output of a hash function may look random, it is only as unpredictable as the input that is fed into it.
3. d - The Bearer auth scheme is used for tokens.
4. b - Store keys in a keystore or other secure storage (see part 3 of this book for other options). Keys should not be stored in the same database as the data they are protecting and should never be hard coded. A password is not a suitable key for HMAC.
5. e - Always use `MessageDigest.equals` or another constant-time equality test to compare HMAC tags.
6. d - CQRS allows you to use different database users for queries vs database updates with only the minimum privileges needed for each task. As described in section 5.3.2 this can reduce the damage that an SQL injection attack can cause.

[1] If you want to allow requests from a different registerable domain then you will need to remove the SameSite attribute from the session cookies.

[2] https://support.apple.com/en-gb/guide/mac-help/mchl732d3c0a/mac

[3] The syntax of the Bearer scheme allows tokens that are base64-encoded, which is sufficient for most token formats in common use. It doesn't say how to encode tokens that do not conform to this syntax.

[4] Some older versions of Safari would disable local storage in private browsing mode, but this has been fixed since version 12.